

Security Hardened WSGI & ASGI Servers Guide

This guide contains secure commands and explanations for running Python WSGI and ASGI servers in production environments, including Gunicorn, Uvicorn, Hypercorn, Waitress, and the Gunicorn+Uvicorn combo.

Assumptions:

- Run behind a reverse proxy (nginx/HAProxy) for TLS and rate limiting.
- Use non-root user and Unix sockets for internal binding.

Gunicorn (WSGI)

```
gunicorn main:app \  
  --bind unix:/run/myapp.sock \  
  --workers 3 \  
  --user=www-data --group=www-data \  
  --timeout 30 \  
  --limit-request-line 4094 \  
  --limit-request-fields 100 \  
  --access-logfile /var/log/gunicorn/access.log \  
  --error-logfile /var/log/gunicorn/error.log
```

- main:app -> WSGI callable in main.py
- --bind -> Bind to Unix socket (not public IP)
- --workers -> Number of worker processes
- --user/--group -> Drop privileges
- --timeout -> Kill hanging workers
- --limit-request-line/fields -> Protect against large request DoS
- --access-logfile / --error-logfile -> Logging

Uvicorn (ASGI)

```
uvicorn main:app \  
  --uds /run/myapp.sock \  
  --workers 4 \  
  --proxy-headers \  
  --forwarded-allow-ips="127.0.0.1" \  
  --timeout-keep-alive 30 \  
  --log-config logging.yaml
```

- main:app -> ASGI callable
- --uds -> Unix socket binding
- --workers -> Number of worker processes
- --proxy-headers -> Respect X-Forwarded-* headers from proxy

- --forwarded-allow-ips -> Trust only localhost proxy
- --timeout-keep-alive -> Close idle connections after 30s
- --log-config -> Custom logging config

Hypercorn (ASGI)

```
hypercorn main:app \
  --bind unix:/run/myapp.sock \
  --workers 4 \
  --keep-alive 30 \
  --access-log /var/log/hypercorn/access.log \
  --error-log /var/log/hypercorn/error.log
```

- main:app -> ASGI callable
- --bind -> Unix socket binding
- --workers -> Worker processes
- --keep-alive -> Close idle connections after 30s
- --access-log / --error-log -> Logging

Waitress (WSGI)

```
waitress-serve \
  --listen=127.0.0.1:8080 \
  --threads=4 \
  --connection-limit=100 \
  --channel-timeout=30 \
  --ident='' \
  main:app
```

- main:app -> WSGI callable
- --listen -> Bind to localhost only
- --threads -> Worker threads
- --connection-limit -> Max simultaneous connections
- --channel-timeout -> Idle connection timeout
- --ident="" -> Removes server header

Gunicorn + Uvicorn Workers

```
gunicorn main:app \
  -k uvicorn.workers.UvicornWorker \
  --bind unix:/run/myapp.sock \
  --workers 4 \
  --user=www-data --group=www-data \
  --timeout 30 \
  --access-logfile /var/log/gunicorn/access.log \
  --error-logfile /var/log/gunicorn/error.log
```

- -k uvicorn.workers.UvicornWorker -> Use Uvicorn async workers with Gunicorn master
- Other flags same as Gunicorn above

Final Security Checklist

1. Run behind nginx/HAProxy for TLS termination.
2. Bind server to Unix socket or 127.0.0.1.
3. Run as non-root user and group.
4. Set timeouts, request limits, and max workers.
5. Trust proxy headers explicitly.
6. Enable access/error logging.
7. Keep server packages and OS patched.
8. Use firewall and OS security features (AppArmor/SELinux).